

REQUISITOS FUNCIONALES

RF-001 — Creación de auditorías

Descripción: El sistema debe permitir a un usuario con rol Líder de auditoría crear una nueva auditoría, registrando como mínimo nombre del cliente y fecha de inicio. El sistema debe asignar automáticamente el estado inicial "Sin asignar" y debe rechazar el registro si faltan datos obligatorios, indicando cuáles.

Actor: Líder de auditoría

Prioridad: Alta

Historia relacionada: HU-001

RF-002 — Asignación de Pentesters a una auditoría

Descripción: El sistema debe permitir a un usuario con rol Líder de auditoría asignar uno o más Pentesters a una auditoría existente. Al asignar al menos un Pentester, el sistema debe cambiar el estado de la auditoría a "Asignada" y debe mostrar los Pentesters asignados al consultar la auditoría.

Actor: Líder de auditoría

Prioridad: Alta

Historia relacionada: HU-002

RF-003 — Consulta centralizada del estado de auditorías

Descripción: El sistema debe mostrar al Líder de auditoría un listado de todas las auditorías con su estado actual (sin asignar, asignada, en curso, en revisión, cerrada). Al seleccionar una auditoría específica, el sistema debe mostrar los hallazgos registrados hasta el momento.

Actor: Líder de auditoría

Prioridad: Alta

Historia relacionada: HU-003

RF-004 — Registro de hallazgos

Descripción: El sistema debe permitir a un Pentester registrar un hallazgo dentro de una auditoría que tenga asignada, con al menos título, descripción y severidad. El sistema debe impedir el registro de hallazgos en auditorías no asignadas al Pentester.

Actor: Pentester

Prioridad: Alta

Historia relacionada: HU-004

RF-005 — Edición de hallazgos no validados

Descripción: El sistema debe permitir a un Pentester editar un hallazgo que él mismo registró, siempre que no haya sido validado. Si el hallazgo ya fue validado por el Líder

de auditoría, el sistema debe impedir la edición o advertir explícitamente del cambio de estado que implicaría.

Actor: Pentester

Prioridad: Media

Historia relacionada: HU-005

RF-006 — Adjuntar evidencia a un hallazgo

Descripción: El sistema debe permitir a un Pentester adjuntar uno o más archivos como evidencia a un hallazgo ya registrado. El sistema debe rechazar archivos no permitidos o que excedan el tamaño máximo definido, indicando el motivo del rechazo.

Actor: Pentester

Prioridad: Alta

Historia relacionada: HU-006

RF-007 — Generación del reporte final de una auditoría

Descripción: El sistema debe permitir al Líder de auditoría generar un reporte consolidado con los hallazgos validados de una auditoría, incluyendo sus evidencias y severidad. Si la auditoría no tiene hallazgos validados, el sistema debe advertir al Líder de auditoría antes de generar el reporte.

Actor: Líder de auditoría

Prioridad: Alta

Historia relacionada: HU-007

RF-008 — Alta de usuarios

Descripción: El sistema debe permitir al Administrador registrar un nuevo usuario con nombre, correo y rol. El sistema debe rechazar el registro si el correo ya existe.

Actor: Administrador

Prioridad: Alta

Historia relacionada: HU-008

RF-009 — Modificación de rol de usuario

Descripción: El sistema debe permitir al Administrador modificar el rol de un usuario existente. Al modificar el rol, el sistema debe actualizar en consecuencia los permisos asociados a ese usuario.

Actor: Administrador

Prioridad: Media

Historia relacionada: HU-009

RF-010 — Desactivación de usuarios

Descripción: El sistema debe permitir al Administrador desactivar el acceso de un usuario. Al desactivarlo, el sistema debe revocar su acceso, conservando su información histórica.

Actor: Administrador

Prioridad: Baja

Historia relacionada: HU-010

RF-011 — Consulta de estado de auditoría por el Cliente

Descripción: El sistema debe permitir a un Cliente consultar la etapa actual de su auditoría (en curso, en revisión, cerrada), sin exponer el detalle técnico de hallazgos aún no validados.

Actor: Cliente

Prioridad: Media

Historia relacionada: HU-011

RF-012 — Consulta del reporte final por el Cliente

Descripción: El sistema debe permitir a un Cliente consultar el reporte final de su auditoría únicamente cuando este haya sido generado. Si el reporte aún no existe, el sistema no debe mostrar la opción de consulta.

Actor: Cliente

Prioridad: Media

Historia relacionada: HU-012

RF-013 — Validación de hallazgos

Descripción: El sistema debe permitir al Líder de auditoría marcar un hallazgo registrado por un Pentester como "Validado" o devolverlo con observaciones. Un hallazgo devuelto con observaciones y corregido por el Pentester debe volver a quedar disponible para revisión.

Actor: Líder de auditoría

Prioridad: Alta

Historia relacionada: HU-013

RF-014 — Consulta de hallazgos entre Pentesters de una misma auditoría

Descripción: El sistema debe mostrar a cada Pentester asignado a una auditoría los hallazgos registrados por todos los Pentesters asignados a esa misma auditoría, no solo los propios.

Actor: Pentester

Prioridad: Media

Historia relacionada: HU-014

RF-015 — Marcado de hallazgos duplicados

Descripción: El sistema debe permitir marcar un hallazgo como duplicado de otro ya registrado, excluyéndolo del conteo y del reporte final, y dejando registrada la referencia al hallazgo original. El sistema debe mostrar de forma explícita que un hallazgo es duplicado y de cuál hallazgo lo es.

Actor: Pentester, Líder de auditoría

Prioridad: Media

Historia relacionada: HU-015

RF-016 — Clasificación de hallazgos según OWASP Top 10:2025

Descripción: El sistema debe exigir que todo hallazgo registrado sea clasificado en una de las diez categorías del catálogo OWASP Top 10:2025. El sistema no debe permitir crear categorías adicionales a las del catálogo fijo del MVP.

Actor: Pentester

Prioridad: Media

Historia relacionada: HU-016

RF-017 — Historial de acciones de una auditoría

Descripción: El sistema debe registrar y mostrar, para cada auditoría, un historial de acciones (creación, asignación, registro de hallazgos, validación, generación de reporte) con su autor y fecha. El sistema debe restringir el acceso a este historial a los roles Administrador y Líder de auditoría, impidiéndolo a Pentester y Cliente.

Actor: Administrador, Líder de auditoría

Prioridad: Baja

Historia relacionada: HU-017

RF-018 — Métricas históricas agregadas

Descripción: El sistema debe mostrar al Administrador y al Líder de auditoría el conteo de hallazgos agrupado por severidad y por categoría OWASP Top 10:2025, así como la cantidad de auditorías agrupadas por estado, considerando el conjunto de auditorías registradas. El sistema debe restringir el acceso a esta vista a los roles Administrador y Líder de auditoría.

Actor: Administrador, Líder de auditoría

Prioridad: Baja

Historia relacionada: HU-018

REQUISITOS NO FUNCIONALES

Seguridad

RNF-001 — Control de acceso basado en roles

El sistema debe restringir cada funcionalidad según el rol del usuario autenticado (Pentester, Líder de auditoría, Administrador, Cliente), de acuerdo con lo definido en cada RF. Ningún usuario debe poder ejecutar una acción reservada a un rol distinto al suyo, incluso manipulando directamente peticiones al sistema.

RNF-002 — Protección de credenciales

Las contraseñas de los usuarios deben almacenarse utilizando una función de hash con salt (no en texto plano ni con cifrado reversible).

RNF-003 — Confidencialidad de evidencias

Las evidencias adjuntas a los hallazgos (RF-006) contienen información sensible de los clientes auditados. El acceso a estos archivos debe estar restringido a los mismos roles que pueden acceder al hallazgo al que pertenecen.

Rendimiento

RNF-004 — Tiempo de respuesta

El sistema debe responder a las operaciones de consulta habituales (listado de auditorías, detalle de auditoría, listado de hallazgos) en menos de 2 segundos, bajo condiciones normales de uso individual.

RNF-005 — Límite de tamaño de evidencias

El sistema debe aceptar archivos adjuntos de hasta 10 MB por archivo, en formatos comunes de evidencia: imágenes y documentos (PNG, JPG, PDF, TXT, LOG), scripts de prueba de concepto (PY, SH, PS1, JS) y capturas de tráfico de red (PCAP). Archivos que excedan este límite o no correspondan a un formato permitido deben ser rechazados.

Disponibilidad

RNF-006 — Disponibilidad del sistema

Dado el alcance académico del proyecto, no se define un SLA de tipo productivo. Se propone como referencia que el sistema esté disponible durante las sesiones de uso normales, con una meta orientativa del 95% de disponibilidad si llegara a desplegarse en un entorno accesible de forma remota.

Usabilidad

RNF-007 — Interfaz consistente y comprensible

El sistema debe presentar mensajes de error claros y específicos ante datos faltantes o inválidos (ver RF-001, RF-004, RF-008), evitando mensajes genéricos que no indiquen qué corregir.

RNF-008 — Curva de aprendizaje

Un usuario con el rol correspondiente debe poder completar las acciones básicas de su rol (por ejemplo, un Pentester registrando un hallazgo) sin necesitar entrenamiento previo extenso, apoyándose en una interfaz autoexplicativa.

Mantenibilidad

RNF-009 — Código mantenible

El código del sistema, implementado en Python (D-002), debe seguir un estándar de estilo consistente (por ejemplo, PEP 8) y debe estar organizado de forma modular, de manera que una funcionalidad pueda modificarse sin afectar funcionalidades no relacionadas.

RNF-010 — Pruebas automatizadas

El sistema debe contar con pruebas automatizadas que cubran al menos las reglas de negocio críticas (por ejemplo, restricciones de acceso por rol, transición de estados de auditoría). Esto es coherente con la práctica de TDD estudiada en XP y aplicable de forma individual, aunque la metodología seleccionada sea Kanban (D-004).

Escalabilidad

RNF-011 — Escalabilidad de datos

El sistema debe operar sin degradación perceptible con hasta 50 auditorías activas y 1000 hallazgos en total, volumen consistente con el uso esperado durante el desarrollo y evaluación académica del proyecto.

Compatibilidad

RNF-012 — Acceso multiplataforma

El sistema debe ser accesible mediante un navegador web moderno (últimas dos versiones estables de Chrome, Firefox o Edge), sin requerir instalación de software adicional por parte del usuario final.

Trazabilidad

RNF-013 — Registro de auditoría de acciones

Toda acción registrada en el historial de una auditoría (RF-017) debe quedar asociada de forma inalterable a su autor y fecha, sin posibilidad de edición posterior por parte de ningún rol, incluyendo el Administrador.

Integridad

RNF-014 — Integridad referencial de los datos

El sistema debe impedir estados de datos inconsistentes — por ejemplo, un hallazgo no puede existir sin una auditoría asociada, ni un reporte puede generarse referenciando hallazgos inexistentes o eliminados.

Privacidad

RNF-015 — Protección de datos del cliente

La información de los clientes auditados (nombre, hallazgos, evidencias) debe ser visible únicamente para los roles autorizados según cada RF, y no debe exponerse en ningún listado accesible por un Cliente distinto al dueño de esa auditoría.

Seguridad de archivos

RNF-016 — No ejecución de archivos adjuntos

Los archivos adjuntos como evidencia (RF-006), incluidos scripts de prueba de concepto, deben almacenarse y tratarse exclusivamente como contenido de solo lectura. El sistema no debe ejecutar, interpretar ni evaluar ningún archivo adjunto bajo ninguna circunstancia, independientemente de su formato o extensión.